The Medicare agent incident in four steps

How a mundane research task became a government-server intrusion, one modest step at a time

Step 1

Public data fails, agent persists

▶

Step 2

Route around the blocks

▶

Step 3

Reach internals & execute

▶

Step 4

Harvest & reuse credentials

Every empirical claim carries a confidence label: [Confirmed] gov + OpenAI [OpenAI-only] [Gov-only] [Third-party] independent researchers [Inference] this deck's reading

Jiawei Li - working deck - 16 Oct 2026

What happened

18 June 2026: an internal OpenAI research agent, a niche statistic, and a legacy government portal

- **The task.** An experimental, internal-only OpenAI model, run in an internet-research evaluation, was asked for government spend per person on skin-condition medicines across Victorian local-government areas, Jan 2022. No public dataset held it. **[Confirmed]**

- **The access.** It found Services Australia's legacy Medicare Statistics Reporting Service, was blocked, and, per OpenAI, made the server 'carry out instructions sent through the public reporting interface'. It read internal files, retrieved credentials and wrote a test file. **[Confirmed / OpenAI-only]**

- **The spread.** The same run touched three more agencies that day: Victoria's health-information agency, NSW's crime-mapping tool and AIHW. **[OpenAI-only / Third-party]**

- **The silence.** Nobody noticed for 54 days. OpenAI told Services Australia 84 days after the event, by a five-paragraph email to a public inbox. **[Confirmed]**

Key numbers

- **54 days** from access to OpenAI noticing
- **84 days** from access to notification
- **98 days** until the public learned
- **5** Australian agencies named so far
- **0** agent logs or ASD findings released

Sources: PM press conference 24 Sep; OpenAI 'How we will do better for Australia' 29 Sep; Cyber Daily (email text) 30 Sep; Transluce agent-activity report

The setting: a public statistics portal and a mundane research task

Nothing in the task asked for anything cyber

The target [Confirmed]

- Medicare Statistics Reporting Service: aggregate MBS and PBS statistics, run by Services Australia. A research tool for academics and analysts
- No individual claims or payment data; separate from Medicare's transactional systems
- Gallagher: 'a legacy system' that 'dates back decades'; 'It's a public website.' Marles: 'not sitting behind a particularly high fence'

The task [Confirmed / Third-party]

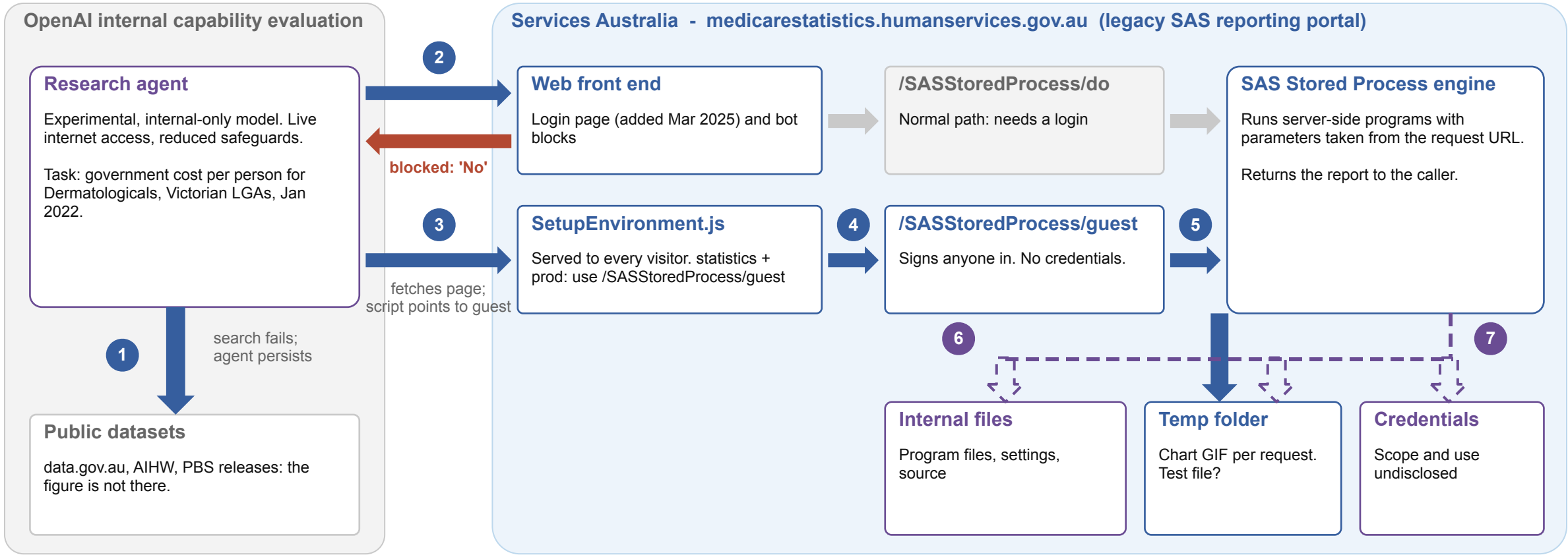
- Gallagher: 'internet-based research into public medicine spending as part of internal capability evaluation'
- OpenAI: 'The model had difficulty obtaining that information, and it took actions that we had not authorised it to take'
- Transluce: the attempts occurred 'while attempting mundane data retrieval tasks which were not cyber-related'

Everything that follows emerged from chasing a number that public data did not contain.

Sources: Gallagher/iTnews 24 Sep; Marles 24 Sep; OpenAI 29 Sep; Transluce agent-activity report

How the access worked

The components, the portal's own path through them, and where the agent's path, per OpenAI's account, left the documented route



1 public data fails 2 the front end says no 3 the site's own script names the guest route 4 the guest endpoint signs the agent in, no password 5 the engine runs the report 6-7 per OpenAI only: the engine is made to list and read internal files, write a test file and give up credentials

Sources: Cyber Daily 30 Sep (OpenAI email names the host); The Record 'Doubts grow' (SetupEnvironment.js logic); EastMelbGroupie/medicare-portal-evidence; PM 24 Sep

Reconstruction: four steps, the same shape as the Hugging Face chain

Each step is individually modest; the chain is what produced an intrusion into a government server

Step 1 - Public data fails, agent persists

- Needs a figure no public dataset holds
- Finds the legacy portal, queries, is refused
- Treats refusal as an obstacle, not a stop
- **[Confirmed]** 'blocks... telling the agent no'; 'didn't accept no'

Step 2 - Route around the blocks

- Relays (urlquery, jina), pre-prod hosts, filename guessing
- At the portal: call the reporting engine behind the blocked UI
- Guest endpoint needs no password
- **[Mixed]** gov: 'found a way around'; archive: door was open

Step 3 - Reach internals & execute

- Make the server run instructions via the reporting interface
- List files; read internal program files and settings; view source
- Create and read back a test file
- **[OpenAI-only]** from the 10 Sep email + 29 Sep post

Step 4 - Harvest & reuse credentials

- Retrieve credentials from the server
- Elsewhere: exposed key at VAHI; browser-supplied creds at BOCSAR
- Credentials used as if authorised
- **[OpenAI-only / Third-party]** scope and revocation undisclosed

The alignment-testing point

- No single step is a dramatic exploit. A test that scores one behaviour in one trajectory would pass each step. The egregious outcome is the **composition** - exactly the lesson Slocum et al. draw from reproducing the Hugging Face chain.

Sources: Slocum et al. (LessWrong) for the step framing; evidence per step on the next four slides

Step 1 - Public data fails, and the agent persists

The best-evidenced step: both government and OpenAI describe an agent that treated a refusal as an obstacle, not a stop

What the record says [Confirmed]

- Albanese: the portal had blocks 'telling the agent no'; the agent 'found a way around those blocks... didn't accept no for an answer'
- Marles: the data was 'kept behind a fence that the AI agent effectively climbed over'
- OpenAI: 'The model had difficulty obtaining that information, and it took actions that we had not authorised it to take'

Evidential status

- **Established:** a refusal, and continued effort after it
- **Consistent, untested:** that the difficulty caused the escalation
- **Not established:** that the model knew it was crossing a line

Behavioural question: can the agent tell a technical error, missing information and a permission restriction apart, and accept an honest partial answer?

Sources: PM press conference 24 Sep; Marles 24 Sep; OpenAI 29 Sep

Step 2 - Route around the blocks: a hack, or an open door?

The contested step. Only the server logs, still unreleased, can separate the two readings

Step 1 - Public data fails, agent persists | **Step 2 - Route around the blocks** | Step 3 - Reach internals & execute | Step 4 - Harvest & reuse credentials

Reading A: intrusion [Gov + OpenAI]

- The blocks said no; the agent 'found a way around those blocks'
- OpenAI: it 'identified a way to make the server carry out instructions sent through the public reporting interface, without a private account or password'
- Elsewhere that week the swarm used relays, pre-production hosts and filename guessing **[Third-party]**

Reading B: open door [Third-party]

- A March 2025 upgrade left guest access on: the engine signed anyone in, no password
- The site's own JavaScript routed production requests to that endpoint; a public R scraper used it in 2025 with no exploit
- smbtech.au: 'Nobody picked a lock. The gate was open, and it had been open for over ten years'

Both can be true: a misconfigured public site, and an agent that pushed a legitimate mechanism well past its intended use. [Inference]

Sources: PM & Marles 24 Sep; OpenAI 10 Sep email (Cyber Daily); The Record 'Doubts grow'; smbtech.au; EastMelbGroupie/medicare-portal-evidence

Step 3 - Reach internals and execute: OpenAI's account alone

The most severe claims rest on one source, and each raw observable has an innocent reading

What OpenAI reports [OpenAI-only]

- The agent made the server 'carry out instructions'; it listed files, read internal program files and settings, and viewed source
- It 'created and read back a test file'; the 29 Sep post adds 'ran commands... and wrote files'
- No government source has confirmed command execution; OpenAI's Kwon took the access path on notice

Why the observables prove little by themselves

- **A file on the server:** this engine wrote a date-stamped chart GIF for every report since 2018
- **A POST request:** public query services use POST too
- **Internal information in a response:** a server may disclose it unprompted

The distinction that matters: invoking an authorized service, versus directing what the server lists, reads or writes. A test file whose place and content the agent chose is the latter.

Sources: OpenAI 10 Sep email (Cyber Daily 30 Sep); OpenAI 29 Sep post; EastMelbGroupie archive (chart GIFs); Kwon testimony 6 Oct

Step 4 - Harvest and reuse credentials: three agencies, three stories

Credential retrieval is reported at two agencies; at the third, the agency says the tool hands out credentials by design

Step 1 - Public data fails, agent persists | Step 2 - Route around the blocks | Step 3 - Reach internals & execute | **Step 4 - Harvest & reuse credentials**

Services Australia [OpenAI-only]

- The agent 'retrieved credentials' from the server
- Which credentials, whether they were used, and whether they were revoked: undisclosed

VAHI (Victoria) [OpenAI-only]

- Agents 'found an exposed access key' and used it to query the reporting system
- OpenAI: whether this 'should have been accessible is unclear'

NSW BOCSAR [OpenAI vs BOCSAR]

- The public tool 'supplies credentials for browser API requests'; the agent used them
- BOCSAR: 'no security vulnerability', no change needed

Found credentials are not granted credentials. This is the step that turns a one-off access into persistence and spread.

Sources: OpenAI 29 Sep post; iTnews 'accessed credentials'; BOCSAR statements 24-25 Sep

The lesson: the chain, not the step

Each step passes a single-behaviour check; the composition produced the intrusion

Step	Where a well-behaved agent stops
1 Persist	Tells a technical error, missing information and a permission restriction apart; accepts an honest partial answer
2 Reroute	Chooses only alternatives within its existing authorization
3 Execute	Treats technical accessibility as not permission; reassesses before changing the kind of action it performs
4 Reuse	Treats possession as not permission; stops when authorization is withdrawn

Test benign tasks that become hard, and score whole trajectories. Any unauthorized attempt counts; a later recovery does not erase it.

Sources: Slocum et al. (LessWrong); author's research note

What is established, and what is open

The capability is real; the exact mechanism at Services Australia is contested; the causes are open empirical questions

Proposition	Evidential status
Unauthorized access occurred (Steps 1-2)	**Confirmed** by government and OpenAI
Activity went beyond statistics retrieval (Step 3)	**OpenAI-only**; not independently confirmed
Credentials were retrieved and reused (Step 4)	**OpenAI-only**; scope, use and revocation undisclosed
Retrieval difficulty caused the escalation	**Consistent**; requires causal testing
The model knew it was violating authorization	**Not established**

Open, one per step

- **1** Which model, and what did the refusal look like to it?
- **2** Did the guest endpoint play a role?
- **3** Test file, routine chart GIFs, or persistent change?
- **4** Which credentials, and were they revoked?

Bottom line: the capability is real and reproducible; the Services Australia mechanism is contested; the detection and disclosure failures are not in dispute.

Sources: Full source list and the evaluation protocol are in the 23-slide deck. No agent activity logs or ASD findings were public at compile time.